



LIVECAMPUS

Remédiation et Législation

MINI CAS 4

ÉCOLE

Livecampus

PROFESSEUR

M. AUMAGY Yannick

GROUPE

G1

COURS

Remédiation et Législation

LIVRABLE

MINI CAS 4

CHAPITRES

cours global

MEMBRES DU GROUPE



BADET Mael



LEBLOND Tristan



LOURENCO Quentin



MASIA Antoine

SOMMAIRE

ÉNONCÉ DU MINI-CAS	3
Contexte	3
RÉPONSES AUX TÂCHES	4
1. Analyser la situation et qualifier les risques	4
2. Déterminer les obligations et responsabilités	13
3. Proposer un plan de sécurisation avant lancement	15
4. Définir les critères de décision de mise en production	17
5. Préparer l'organisation en cas d'incident après lancement	21
LIVRABLE ATTENDU	22
Contenu du livrable	22
GLOSSAIRE	23

ÉNONCÉ DU MINI-CAS

Contexte

Une entreprise française spécialisée dans les **services numériques aux professionnels** vient de remporter un important contrat pour exploiter une nouvelle plateforme destinée à plusieurs grandes entreprises et organismes publics.

Cette plateforme doit permettre à plusieurs milliers d'utilisateurs d'échanger des **documents confidentiels**, de gérer leurs comptes clients et d'accéder à différents services en ligne.

La mise en production définitive est prévue dans **trois semaines**. Cependant, plusieurs éléments viennent inquiéter la direction :

- un **audit récent** a identifié plusieurs **vulnérabilités importantes** sur des serveurs exposés à Internet ;
- un **prestataire externe** dispose encore de **comptes administrateurs permanents** sur une partie de l'infrastructure ;
- plusieurs tentatives de **phishing ciblé** ont été reçues par des membres de la direction et de l'équipe informatique ;
- les **journaux de sécurité** montrent des **connexions inhabituelles** provenant de l'étranger, sans qu'une intrusion ait pour l'instant été confirmée ;
- le **plan de reprise d'activité** n'a jamais été testé dans les conditions réelles ;
- les **responsabilités** entre l'entreprise, son hébergeur et plusieurs sous-traitants restent **imprécises** en cas d'incident majeur.

La direction hésite entre **maintenir la date de lancement**, **reporter la mise en production** ou **lancer le service avec des mesures compensatoires**.

Elle demande à votre groupe de réaliser une **analyse globale** de la situation et de présenter une **recommandation argumentée**.

Cette situation mobilise notamment les notions de **cadre réglementaire**, **analyse de la menace**, **stratégie**, **gouvernance**, **détection**, **réponse aux incidents**, **résilience** et **retour d'expérience** étudiées pendant l'ensemble du cours.

RÉPONSES AUX TÂCHES

1. Analyser la situation et qualifier les risques

Identifiez les principaux risques techniques, humains, organisationnels, réglementaires et liés aux prestataires.

Pour chacun des risques principaux :

- estimez sa **probabilité** ;
- estimez son niveau de **gravité** ;
- précisez ses **conséquences potentielles** ;
- déterminez s'il est **acceptable** avant la mise en production.

Présentez votre analyse dans un **tableau de risques hiérarchisé**.

1.1. Méthode d'évaluation

L'analyse porte sur les risques **techniques, humains, organisationnels, réglementaires et liés aux prestataires**. Elle tient compte du contexte particulier de la plateforme : exposition à Internet, traitement de documents confidentiels, gestion de comptes clients, plusieurs milliers d'utilisateurs et présence probable de données à caractère personnel.

Les niveaux suivants sont utilisés :

- **Probabilité** : 1 – faible ; 2 – moyenne ; 3 – élevée ; 4 – très élevée.
- **Gravité** : 1 – mineure ; 2 – significative ; 3 – majeure ; 4 – critique.
- **Criticité** : probabilité × gravité.

Score	Niveau de risque	Principe de traitement
12 à 16	Critique	Risque inacceptable : traitement obligatoire avant la mise en production.
8 à 11	Élevé	Réduction indispensable avant le lancement, sauf dérogation formelle et mesures compensatoires fortes.
4 à 7	Modéré	Risque à réduire et à surveiller ; acceptation possible sous conditions.
1 à 3	Faible	Risque généralement acceptable avec un suivi courant.

Cette cotation est une première estimation. Elle devra être confirmée à partir des résultats détaillés de l'audit, de l'architecture technique, de la nature exacte des données et des engagements contractuels.

1.2. Tableau des risques hiérarchisé

Rang	Risque principal	Catégorie	Probabilité	Gravité	Criticité	Conséquences potentielles	Acceptable avant la mise en production ?
1	Exploitation des vulnérabilités importantes présentes sur les serveurs exposés à Internet	Technique	4 – Très élevée	4 – Critique	16 – Critique	Intrusion, exécution de code, compromission de comptes, vol ou modification de documents, indisponibilité de la plateforme, propagation dans le système d'information et atteinte à l'image de l'entreprise.	Non. Les vulnérabilités critiques ou importantes exploitables doivent être corrigées ou isolées, puis faire l'objet de tests de non-régression et d'un nouveau contrôle de sécurité.
2	Compromission par les comptes administrateurs permanents du prestataire	Prestataire / technique	4 – Très élevée	4 – Critique	16 – Critique	Utilisation abusive ou détournement d'un compte privilégié, élévation de privilèges, désactivation des protections, accès massif aux données, sabotage ou difficulté à attribuer les actions réalisées.	Non. Les accès permanents doivent être supprimés au profit d'accès nominatifs, temporaires, limités, authentifiés par MFA ^{1.1} et intégralement journalisés.

Rang	Risque principal	Catégorie	Probabilité	Gravité	Criticité	Conséquences potentielles	Acceptable avant la mise en production ?
3	Intrusion potentielle déjà en cours, révélée par les connexions inhabituelles depuis l'étranger	Technique / détection	4 – Très élevée	4 – Critique	16 – Critique	Maintien d'un attaquant dans le système, exfiltration silencieuse, création de portes dérobées ^{1.2} , altération des journaux et compromission de la future plateforme dès son lancement.	Non. Une investigation doit déterminer l'origine, la légitimité et l'étendue de ces connexions avant toute ouverture du service. L'absence de preuve d'intrusion ne constitue pas une preuve d'absence d'intrusion.
4	Indisponibilité prolongée ou perte de données en raison d'un PRA jamais testé en conditions réelles^{1.3}	Résilience / technique	3 – Élevée	4 – Critique	12 – Critique	Restauration impossible ou trop lente, perte de documents, interruption des services clients, non-respect des objectifs de reprise, pénalités contractuelles et rupture de confiance.	Non. Un test complet de restauration et de bascule doit confirmer les sauvegardes, le RTO ^{1.4} , le RPO ^{1.5} , les responsabilités et les procédures de retour à la normale.

Rang	Risque principal	Catégorie	Probabilité	Gravité	Criticité	Conséquences potentielles	Acceptable avant la mise en production ?
5	Vol d'identifiants ou compromission d'un compte à privilèges à la suite d'un phishing ciblé ^{1.6}	Humain / technique	3 – Élevée	4 – Critique	12 – Critique	Accès frauduleux aux comptes de direction ou d'administration, fraude, divulgation de données sensibles, mouvement latéral, usurpation d'identité et contournement des contrôles internes.	Non en l'état. Il faut renforcer immédiatement la MFA, la protection de la messagerie, les procédures de signalement et la sensibilisation ciblée des personnes exposées.
6	Fuite, altération ou destruction de documents confidentiels et de données personnelles	Réglementaire / métier	3 – Élevée	4 – Critique	12 – Critique	Atteinte à la confidentialité, au secret des affaires et aux droits des personnes ; notification potentielle à la CNIL ^{1.7} sous 72 heures lorsqu'une violation de données présente un risque ; information éventuelle des personnes ; contentieux, sanctions, pertes commerciales et préjudice réputationnel.	Non. La confidentialité, l'intégrité, le chiffrement, le contrôle des accès, la traçabilité et la gestion des violations doivent être démontrés avant l'ouverture.

Rang	Risque principal	Catégorie	Probabilité	Gravité	Criticité	Conséquences potentielles	Acceptable avant la mise en production ?
7	Répartition imprécise des responsabilités entre l'entreprise, l'hébergeur et les sous-traitants	Organisationnel / prestataire	3 – Élevée	4 – Critique	12 – Critique	Retard dans la détection, le confinement, la notification et la restauration ; décisions contradictoires ; absence d'interlocuteur disponible ; défaut de preuve ; litiges et non-respect des délais réglementaires ou contractuels.	Non. Les rôles doivent être formalisés au moyen d'une matrice RACI ^{1.8} , de clauses contractuelles, d'une procédure d'escalade et d'un dispositif d'astreinte testé.
8	Défaut de conformité des relations de sous-traitance et de la protection des données	Réglementaire / prestataire	3 – Élevée	3 – Majeure	9 – Élevé	Clauses insuffisantes relatives à la sécurité, à la confidentialité, aux notifications, aux audits, à la restitution ou à la suppression des données ; transferts internationaux mal encadrés ; responsabilité juridique et sanctions.	Non sans vérification. Les contrats, l'article 28 du RGPD ^{1.9} , la localisation des données, les éventuels transferts hors EEE et les garanties des sous-traitants doivent être contrôlés.

Rang	Risque principal	Catégorie	Probabilité	Gravité	Criticité	Conséquences potentielles	Acceptable avant la mise en production ?
9	Surveillance et journalisation insuffisantes ou non exploitables	Technique / organisationnel	3 – Élevée	3 – Majeure	9 – Élevé	Détection tardive, absence de corrélation des événements, conservation insuffisante, incapacité à reconstituer l'attaque ou à produire des preuves et allongement du temps de réponse.	Non sans mesures complémentaires. Les sources critiques doivent être centralisées, horodatées, protégées contre l'altération, supervisées et associées à des alertes testées avant le lancement.
10	Gestion insuffisante des identités, des habilitations et du moindre privilège^{1.10}	Technique / organisationnel	3 – Élevée	3 – Majeure	9 – Élevé	Comptes orphelins ou partagés, privilèges excessifs, accès injustifiés aux documents, traçabilité faible et augmentation de l'impact d'un compte compromis.	Non sans revue préalable. Une revue des habilitations et des comptes techniques, administrateurs et prestataires est indispensable avant la production.

Rang	Risque principal	Catégorie	Probabilité	Gravité	Criticité	Conséquences potentielles	Acceptable avant la mise en production ?
11	Réponse aux incidents insuffisamment préparée ou non testée	Organisationnel	2 – Moyenne	4 – Critique	8 – Élevé	Mauvaises décisions sous pression, confinement tardif, perte de preuves, communication incohérente, dépassement des délais de notification et aggravation de l'incident.	Non sans exercice préalable. Le plan de réponse, la cellule de crise, les contacts, les procédures de collecte de preuves et les scénarios de communication doivent être testés au minimum lors d'un exercice sur table 1.11 .
12	Lancement précipité sous contrainte de calendrier	Stratégique / organisationnel	3 – Élevée	3 – Majeure	9 – Élevé	Acceptation implicite de risques non maîtrisés, correctifs incomplets, erreurs de configuration, tests raccourcis, dette de sécurité et incident majeur peu après l'ouverture.	Non en l'état. La décision de lancement doit dépendre de critères de sécurité mesurables et d'une validation formelle, et non uniquement de l'échéance commerciale.

Rang	Risque principal	Catégorie	Probabilité	Gravité	Criticité	Conséquences potentielles	Acceptable avant la mise en production ?
13	Attaque par déni de service ou saturation lors de l'ouverture	Technique / disponibilité	2 – Moyenne	3 – Majeure	6 – Modéré	Indisponibilité du portail, dégradation des performances, échec du lancement, dépassement des capacités et non-respect des engagements de service.	Acceptable sous conditions , après tests de charge, mise en place de protections anti-DDoS ^{1.12} , limitation de débit, supervision et procédure d'escalade avec l'hébergeur.
14	Erreur humaine de configuration ou de déploiement pendant la mise en production	Humain / technique	2 – Moyenne	3 – Majeure	6 – Modéré	Exposition accidentelle d'un service, secret présent dans la configuration, mauvaise règle réseau, perte de disponibilité ou accès non autorisé.	Acceptable sous conditions , avec revue par les pairs, automatisation du déploiement, séparation des rôles, gestion sécurisée des secrets et procédure de retour arrière testée.

1.3. Synthèse de l'analyse

La situation présente **sept risques critiques** et plusieurs risques élevés. Leur cumul est particulièrement préoccupant : un attaquant pourrait exploiter une vulnérabilité exposée à Internet ou un compte privilégié compromis, rester non détecté en raison d'une supervision insuffisante, puis provoquer une fuite de données ou une interruption que le PRA non testé ne permettrait pas de maîtriser correctement.

Les risques ne sont donc pas indépendants. Ils forment une chaîne d'attaque plausible :

1. phishing ciblé ou exploitation d'une vulnérabilité exposée ;
2. compromission d'un compte utilisateur ou administrateur ;
3. élévation de privilèges et déplacement dans l'infrastructure ;
4. consultation, modification ou exfiltration de documents confidentiels ;
5. détection tardive et réponse désorganisée ;
6. restauration incertaine et conséquences réglementaires, contractuelles et réputationnelles.

Sources :

- Cours Livecampus – *Remédiation et Législation*, **chapitre 2** (analyse de la menace, phishing, supply chain)
- Cours Livecampus – *Remédiation et Législation*, **chapitre 3** (disponibilité, confidentialité, résilience)
- Cours Livecampus – *Remédiation et Législation*, **chapitre 5** (détection, journalisation)
- Cours Livecampus – *Remédiation et Législation*, **chapitre 8** (PCA/PRA, chaîne d'approvisionnement)
- CNIL – *Notifier une violation de données personnelles* : <https://www.cnil.fr/fr/services-en-ligne/notifier-une-violation-de-donnees-personnelles>
- CERT-FR – *Les bons réflexes en cas d'intrusion* : <https://www.cert.ssi.gouv.fr/les-bons-reflexes-en-cas-dintrusion-sur-un-systeme-dinformation/>
- NIST – *SP 800-61 Rev. 3* : <https://csrc.nist.gov/pubs/sp/800/61/r3/final>

2. Déterminer les obligations et responsabilités

Identifiez les principaux acteurs concernés par la situation :

- direction ;
- RSSI et équipes techniques ;
- métiers ;
- service juridique ;
- hébergeur ;
- prestataires et sous-traitants ;
- autorités compétentes.

Expliquez les responsabilités de chacun.

Identifiez également les principales **obligations réglementaires ou de notification** susceptibles de s'appliquer si une compromission de données ou un incident majeur était confirmé.

Dans cette situation, plusieurs acteurs sont concernés, et il faut bien clarifier qui fait quoi, surtout que l'énoncé précise justement que les responsabilités entre l'entreprise, l'hébergeur et les sous-traitants restent floues. Voici le rôle de chacun.

La direction

Elle porte la décision finale sur le lancement (maintenir, reporter, ou lancer avec des mesures compensatoires). C'est elle qui doit arbitrer entre la pression commerciale (le contrat, les délais) et le niveau de risque réel de la plateforme. Elle est aussi responsable en dernier ressort si un incident survient après une mise en production trop précipitée.

Le RSSI^{2.1} et les équipes techniques

Ils sont responsables de l'évaluation technique du risque : corriger les vulnérabilités identifiées par l'audit, revoir les accès du prestataire externe qui a encore des comptes administrateurs permanents, et surveiller les connexions suspectes venant de l'étranger. C'est eux qui doivent dire à la direction si la plateforme est "prête" ou non d'un point de vue sécurité.

Les métiers

Ce sont les équipes qui vont utiliser ou faire fonctionner la plateforme au quotidien (gestion des comptes clients, échange de documents). Ils doivent faire remonter les besoins réels du service et évaluer l'impact d'un éventuel report sur leurs activités et sur leurs engagements envers les clients.

Le service juridique

Il doit vérifier que la plateforme respecte le cadre légal avant son lancement, notamment le RGPD puisque des documents confidentiels et des comptes clients sont en jeu. Il doit aussi clarifier contractuellement les responsabilités avec l'hébergeur et les sous-traitants, ce qui n'est pour l'instant pas clair. Enfin, il doit préparer les procédures de notification en cas d'incident (par exemple à la CNIL).

L'hébergeur

Il est responsable de la sécurité de l'infrastructure qu'il fournit (serveurs, réseau). Comme l'audit a révélé des vulnérabilités sur des serveurs exposés à Internet, l'hébergeur a un rôle clé pour corriger ces failles avant le lancement. Ses responsabilités doivent être précisées dans un contrat clair, notamment sur qui doit agir en cas d'incident.

Les prestataires et sous-traitants

Le prestataire qui dispose encore de comptes administrateurs permanents représente un risque direct : ces accès doivent être supprimés ou limités dans le temps. Plus largement, chaque prestataire doit être responsable de la sécurité de ce qu'il gère pour l'entreprise, et l'entreprise doit s'assurer contractuellement qu'ils respectent des règles de sécurité minimales.

Les autorités compétentes

Si une compromission de données personnelles était confirmée, l'entreprise aurait l'obligation de notifier la CNIL dans un délai de 72 heures, comme l'impose le RGPD. Si l'incident touchait un service essentiel ou révélait une faille de grande ampleur, l'ANSSI^{2.2} pourrait aussi être sollicitée pour accompagner la réponse.

Sur les obligations réglementaires en cas d'incident

Deux obligations principales ressortent de ce contexte :

- **Le RGPD** impose de notifier la CNIL sous 72 heures en cas de violation de données personnelles, et d'informer les personnes concernées si le risque pour elles est élevé (ici, les comptes clients et documents confidentiels sont particulièrement sensibles).
- Selon la nature des organismes publics clients de la plateforme, **la directive NIS2**^{2.3} pourrait aussi imposer des obligations de notification si un incident affecte la continuité de services considérés comme importants.

En résumé, chaque acteur a une responsabilité précise, mais le point faible actuel c'est justement que ces responsabilités ne sont pas clairement définies entre l'entreprise, l'hébergeur et les sous-traitants, ce qui doit être corrigé avant le lancement pour éviter toute confusion en cas d'incident.

Sources :

- Cours Livecampus – *Remédiation et Législation*, **chapitre 1** (RGPD, NIS/NIS2, ANSSI, CNIL)
- Cours Livecampus – *Remédiation et Législation*, **chapitre 3-C** (rôle des entités publiques et privées)
- Cours Livecampus – *Remédiation et Législation*, **chapitre 4-B** (coordination interne / prestataires)
- CNIL – *Notifier une violation de données personnelles* (RGPD art. 33, délai 72 h) : <https://www.cnil.fr/fr/services-en-ligne/notifier-une-violation-de-donnees-personnelles>
- CNIL – *Le règlement général sur la protection des données (RGPD)* : <https://www.cnil.fr/fr/reglement-europeen-protection-donnees>
- ANSSI – portail **MonEspaceNIS2** : <https://monespacenis2.cyber.gouv.fr/>
- ANSSI – <https://cyber.gouv.fr/>

3. Proposer un plan de sécurisation avant lancement

Établissez les mesures qui doivent être réalisées pendant les **trois semaines** précédant la mise en production.

Classez-les en trois catégories :

- actions **impératives** avant lancement ;
- actions pouvant être réalisées **rapidement après** lancement ;
- actions d'amélioration à **moyen terme**.

Votre plan devra prendre en compte notamment :

- les vulnérabilités techniques ;
- les comptes et accès privilégiés ;
- les prestataires ;
- la surveillance et la détection ;
- les sauvegardes et la capacité de restauration ;
- la sensibilisation des utilisateurs.

Objectif des 3 semaines : **baissier le risque** avant d'ouvrir la plateforme (documents confidentiels, clients publics).

Avant lancement (impératif)

Domaine	Action
Vulnérabilités	Patcher les failles critiques de l'audit + re-scan
Accès	Couper les admin permanents prestataire → accès temporaires + MFA
Prestataires	Matrice RACI incident signée (entreprise / hébergeur / sous-traitants)
Détection	Qualifier les connexions étrangères ; alertes SIEM ^{3.1} renforcées
Sauvegardes	Tester une restauration (PRA minimal)
Sensibilisation	Briefing anti- phishing direction + IT

Go / no-go : plus de faille critique ouverte, plus d'admin permanent prestataire, connexions suspectes traitées, test PRA OK, RACI signée.

Rapidement après lancement

- Traiter les failles **moyennes**, durcir WAF^{3.2} / configs
- MFA élargie + revue des habilitations
- Affiner les règles SIEM au trafic réel
- 2^e test de restauration + phishing simulé utilisateurs

Moyen terme

- IAM^{3.3}, scans / pentests réguliers, EDR^{3.4}
- Politique **supply chain**^{3.5} prestataires
- SOC^{3.6} / exercices de crise, PRA testé périodiquement
- Formation continue et retours d'expérience

Sources :

- Cours Livecampus – *Remédiation et Législation*, **chapitre 3** (disponibilité, confidentialité, résilience, gouvernance)
- Cours Livecampus – *Remédiation et Législation*, **chapitre 5** (détection SIEM / SOC)
- Cours Livecampus – *Remédiation et Législation*, **chapitre 6** (remédiation, confinement, restauration)
- Cours Livecampus – *Remédiation et Législation*, **chapitre 7** (amélioration continue, sensibilisation)
- Cours Livecampus – *Remédiation et Législation*, **chapitre 8** (PCA/PRA, chaîne d'approvisionnement)
- CERT-FR – *Les bons réflexes en cas d'intrusion* : <https://www.cert.ssi.gouv.fr/les-bons-reflexes-en-cas-dintrusion-sur-un-systeme-dinformation/>
- NIST – *SP 800-61 Rev. 3* (réponse à incident) : <https://csrc.nist.gov/pubs/sp/800/61/r3/final>

4. Définir les critères de décision de mise en production

La direction doit choisir entre :

- **Option A** : maintenir le lancement à la date prévue ;
- **Option B** : reporter la mise en production ;
- **Option C** : lancer le service avec des mesures compensatoires.

Définissez des **critères objectifs** permettant de prendre cette décision. Vous pouvez notamment prendre en compte :

- le niveau de risque résiduel ;
- la criticité des vulnérabilités restantes ;
- les capacités de détection ;
- les capacités de confinement et de restauration ;
- la dépendance aux prestataires ;
- les conséquences financières et opérationnelles d'un report ;
- les obligations réglementaires ;
- l'impact potentiel sur la confiance des clients.

Choisissez ensuite une option et **justifiez votre recommandation**.

4.1. Critères objectifs de décision

Avant de maintenir la date de lancement, la direction doit vérifier que le niveau de risque résiduel est compatible avec la criticité de la plateforme et avec les engagements pris envers les clients et organismes publics.

Critère	Situation actuelle	Condition permettant le lancement	Décision
Vulnérabilités techniques	Plusieurs vulnérabilités importantes sont présentes sur des serveurs exposés à Internet	Les vulnérabilités critiques doivent être corrigées ou compensées de manière fiable	Défavorable
Comptes privilégiés	Un prestataire possède encore des comptes administrateurs permanents	Suppression des comptes permanents inutiles et mise en place d'accès temporaires, nominatifs et tracés	Défavorable
Détection	Des connexions inhabituelles provenant de l'étranger sont déjà observées	Surveillance active, journalisation et capacité à détecter rapidement une activité suspecte	Défavorable / à renforcer
Confinement	La capacité réelle de confinement doit être vérifiée	Procédure permettant d'isoler rapidement un serveur, un compte ou une partie de la plateforme	À tester
Restauration	Le plan de reprise n'a jamais été testé en conditions réelles	Sauvegardes disponibles et restauration testée avec succès	Défavorable
Prestataires	Les responsabilités entre l'entreprise, l'hébergeur et les sous-traitants restent imprécises	Responsabilités, accès et procédures d'intervention clairement définis	Défavorable
Risque résiduel	Plusieurs risques importants restent non maîtrisés	Risque évalué, accepté formellement par la direction et compatible avec la criticité du service	Trop élevé
Confiance des clients	Une attaque après lancement pourrait fortement dégrader la confiance	Capacité à garantir un niveau de sécurité suffisant pour protéger les données et services	Risque élevé

4.2. Seuils de décision

La mise en production ne devrait être autorisée que si les conditions minimales suivantes sont réunies :

- aucune vulnérabilité critique connue ne doit rester sans mesure de traitement acceptable
- les accès administrateurs des prestataires doivent être maîtrisés, nominatifs, limités et traçables
- les connexions inhabituelles doivent faire l'objet d'une investigation et d'une surveillance renforcée
- les capacités de détection et d'alerte doivent être opérationnelles
- les sauvegardes doivent être vérifiées et une restauration doit avoir été testée
- les procédures de confinement et d'arrêt du service doivent être définies et testées
- les responsabilités entre l'entreprise, l'hébergeur et les sous-traitants doivent être éclaircies

4.3. Choix entre les trois options

Option A - Maintenir le lancement à la date prévue :

Difficilement justifiable dans la situation actuelle. Plusieurs failles préoccupantes sont présentes : vulnérabilités sur des serveurs exposés, comptes administrateurs permanents, tentatives de phishing ciblé, connexions inhabituelles et absence de test réel du plan de reprise. Maintenir le calendrier sans réduction préalable des risques exposerait fortement l'entreprise.

Option B - Reporter la mise en production :

Permet d'avoir le temps de corriger les vulnérabilités, sécuriser les comptes privilégiés, tester la restauration, renforcer la détection et clarifier les responsabilités. C'est l'option recommandée si les actions correctives ne peuvent pas être réalisées et validées dans les trois semaines restantes.

Option C - Lancer avec des mesures compensatoires :

Envisageable uniquement si les risques critiques peuvent être suffisamment réduits avant le lancement. Elle nécessiterait notamment un renforcement de la surveillance, une limitation stricte des accès administrateurs, une capacité de confinement rapide, des sauvegardes vérifiées et une procédure de gestion d'incident immédiatement opérationnelle.

4.4. Recommandation

L'option de reporter la mise en production, sauf si l'ensemble des mesures de sécurité critiques peut être réalisé, testé et validé avant la date prévue.

Ce choix est justifié au vu du nombre important de défaillances critiques recensées. Il y a des failles techniques, des comptes ne respectant pas le principe du moindre privilège, tentatives de social engineering, connexions suspectes, une reprise d'activité non testée ainsi que la responsabilité de chaque partie qui n'est pas correctement définie. Le risque global est donc trop important pour considérer le lancement comme maîtrisé.

Sources :

- Cours Livecampus – *Remédiation et Législation*, **chapitre 3** (objectifs stratégiques, confiance numérique)
- Cours Livecampus – *Remédiation et Législation*, **chapitre 8-B** (PCA/PRA, supply chain, résilience)
- Plan de sécurisation (tâche 3) – critères go / no-go avant lancement
- NIST – *SP 800-61 Rev. 3* (évaluation du risque et préparation avant reprise / mise en service) : <https://csrc.nist.gov/pubs/sp/800/61/r3/final>
- ANSSI – <https://cyber.gouv.fr/>

5. Préparer l'organisation en cas d'incident après lancement

Supposez finalement que la plateforme soit mise en production.

Définissez le **dispositif minimal** permettant de réagir efficacement si un incident survient dans les premières semaines :

- conditions d'activation de la cellule de crise ;
- informations à collecter ;
- personnes à prévenir ;
- règles de conservation des preuves ;
- critères de confinement ou d'arrêt du service ;
- organisation de la communication ;
- conditions permettant la reprise du service ;
- organisation du retour d'expérience après l'incident.

L'objectif n'est pas de décrire à nouveau tout le processus de gestion de crise étudié précédemment, mais de montrer comment il doit être **préparé avant la mise en production**.

Dispositif **minimal prêt avant le go-live** (pas de réécriture complète du processus de crise) :

Point	Contenu prêt à l'emploi
Activation cellule	Service down majeur, intrusion / fuite plausible, ou pression médias / clients / autorités
Infos à collecter	Type d'alerte, horodatage, systèmes / comptes, impact users-docs, logs, actions déjà faites
Qui prévenir	RSSI + IT/SOC → direction → DPO ^{5.1} /juridique + com' + métiers → hébergeur/prestataires → CNIL/ANSSI si besoin
Preuves	Pas de wipe avant capture ; allonger rétention logs ; copier hors SI ; tracer qui fait quoi
Confinement / arrêt	Isoler le composant touché ; arrêt global si perte de contrôle des accès ou risque d'exfiltration massive (décision direction sur avis RSSI)
Communication	Porte-parole unique + modèles prêts ; pas de fuite « confirmée » sans preuve ; message rapide anti-rumeurs
Reprise	Menace maîtrisée, secrets renouvelés, faille corrigée, restore saine, surveillance renforcée, com' de reprise validée
Rex	Débrief J+1 + compte rendu sous 15 j (causes, délais, actions)

En bref : décider **à l'avance** quand on escalade, qui on appelle, quand on coupe et quand on rouvre.

Sources :

- Cours Livecampus – *Remédiation et Législation*, **chapitre 4** (cellule de crise, communication)
- Cours Livecampus – *Remédiation et Législation*, **chapitre 5** (collecte de preuves, reporting)
- Cours Livecampus – *Remédiation et Législation*, **chapitre 6** (confinement, restauration)

- Cours Livecampus – *Remédiation et Législation*, **chapitre 7** (retour d'expérience)
- CERT-FR – *Les bons réflexes en cas d'intrusion* : <https://www.cert.ssi.gouv.fr/les-bons-reflexes-en-cas-dintrusion-sur-un-systeme-dinformation/>
- CNIL – *Notifier une violation de données personnelles* : <https://www.cnil.fr/fr/services-en-ligne/notifier-une-violation-de-donnees-personnelles>
- NIST – *SP 800-61 Rev. 3* : <https://csrc.nist.gov/pubs/sp/800/61/r3/final>

LIVRABLE ATTENDU

Un document PDF d'aspect professionnel comprenant :

- une **page de garde** (nom de l'école, nom du cours, nom du professeur, noms des membres du groupe) ;
- une **page reprenant l'énoncé** du mini-cas ;
- des **pages numérotées** avec une présentation claire et professionnelle ;
- des **graphiques, schémas ou images** pour illustrer les analyses et rendre la lecture plus agréable.

Contenu du livrable

- Une **page de synthèse** : présentation de la situation, niveau de risque global et décision recommandée concernant la mise en production.
- Le **détail des analyses** : tableau des risques, responsabilités des acteurs, mesures de sécurisation et critères utilisés pour décider du lancement.
- Vos **recommandations priorisées** : liste des actions impératives avant mise en production, actions à court terme et mesures permettant d'assurer la résilience du service après son lancement.

GLOSSAIRE

Les chiffres en exposant dans le texte (ex. **1.1**, **2.1**, **3.1**) renvoient aux définitions ci-dessous. La première partie du numéro indique la question où le terme apparaît pour la première fois.

- 1.1 MFA** (*Multi-Factor Authentication*) – Authentification à plusieurs facteurs (ex. mot de passe + code / application). [↩](#)
- 1.2 Porte dérobée** (*backdoor*) – Accès secret laissé ou installé par un attaquant pour revenir dans un système après l'intrusion initiale. [↩](#)
- 1.3 PRA** (*Plan de Reprise d'Activité*) – Dispositif pour restaurer les systèmes et données après un sinistre ou un incident majeur (souvent lié au PCA). [↩](#)
- 1.4 RTO** (*Recovery Time Objective*) – Durée maximale acceptable d'interruption d'un service avant reprise. [↩](#)
- 1.5 RPO** (*Recovery Point Objective*) – Perte de données maximale acceptable (ex. : dernières X heures non sauvegardées). [↩](#)
- 1.6 Phishing** – Technique d'ingénierie sociale visant à tromper une victime pour obtenir des identifiants ou déployer un malware. [↩](#)
- 1.7 CNIL** – Commission nationale de l'informatique et des libertés. Autorité de contrôle du RGPD en France. [↩](#)
- 1.8 RACI** – Matrice de responsabilités (*Responsible, Accountable, Consulted, Informed*) qui clarifie qui fait quoi en cas d'incident. [↩](#)
- 1.9 RGPD** – Règlement général sur la protection des données (UE). Impose notamment la notification à l'autorité (CNIL) sous **72 h** en cas de violation présentant un risque pour les personnes. [↩](#)
- 1.10 Moindre privilège** – Principe selon lequel un compte ne dispose que des droits strictement nécessaires à sa mission. [↩](#)
- 1.11 Exercice sur table** (*table-top / TTX*) – Simulation de crise où les décideurs déroulent un scénario et décident des actions, sans toucher au SI de production. [↩](#)
- 1.12 DDoS** (*Distributed Denial of Service*) – Attaque par déni de service distribué saturant un service pour le rendre inaccessible. [↩](#)
- 2.1 RSSI** (*Responsable de la Sécurité des Systèmes d'Information*) – Cadre chargé de piloter la politique de cybersécurité et de coordonner la réponse aux incidents. [↩](#)
- 2.2 ANSSI** – Agence nationale de la sécurité des systèmes d'information. Autorité nationale française en cybersécurité. [↩](#)
- 2.3 NIS2** – Directive européenne sur la sécurité des réseaux et de l'information ; élargit les obligations de sécurité et de notification pour certains acteurs essentiels / importants. [↩](#)
- 3.1 SIEM** (*Security Information and Event Management*) – Plateforme qui centralise les journaux et détecte des anomalies / corrélations. [↩](#)
- 3.2 WAF** (*Web Application Firewall*) – Pare-feu applicatif qui filtre les requêtes HTTP malveillantes. [↩](#)
- 3.3 IAM** (*Identity and Access Management*) – Gestion des identités et des accès (comptes, droits, cycle de vie). [↩](#)
- 3.4 EDR** (*Endpoint Detection and Response*) – Détection et réponse sur les postes / serveurs (endpoints). [↩](#)
- 3.5 Supply chain** (chaîne d'approvisionnement) – Risques liés aux prestataires, éditeurs et sous-traitants dont dépend le SI. [↩](#)
- 3.6 SOC** (*Security Operations Center*) – Centre qui surveille les alertes et coordonne la réponse technique. [↩](#)
- 5.1 DPO** (*Data Protection Officer / Délégué à la protection des données*) – Responsable du respect du RGPD ; intervient pour évaluer et notifier une violation de données. [↩](#)